

ПРАКТИЧЕСКАЯ РАБОТА 3

**Проектирование заголовков безопасности, защита cookie и
прототип сайта клининга**

Выполнил: Аньшин Сергей

Группа: ИСП-406

2026

1 Цель и задачи практической работы

Цель работы — разработать прототип сайта клининга и реализовать меры безопасности, связанные с HTTP-заголовками и файлами cookie.

Для достижения цели требовалось:

- создать простой адаптивный интерфейс сайта клининга;
- реализовать регистрацию, авторизацию и работу с заявками;
- подключить базу данных PostgreSQL;
- добавить уведомление об использовании cookie;
- настроить безопасные параметры сессионного cookie;
- настроить заголовки безопасности в ответах сервера;
- проверить результат средствами разработчика браузера.

2 Используемые средства

В работе использованы HTML, CSS и JavaScript для интерфейса, Python для серверной части, PostgreSQL для хранения пользователей, сессий и заявок, pgAdmin 4 для просмотра базы данных, а также инструменты разработчика Microsoft Edge для проверки HTTP-заголовков и cookie.

3 Разработка прототипа сайта

Создан сайт клининга «ЧистоДома». На главной странице размещены навигация, перечень услуг, форма заявки, регистрация, вход, личный кабинет, поиск и сведения об обработке данных. При первом посещении отображается уведомление об использовании необходимых cookie.

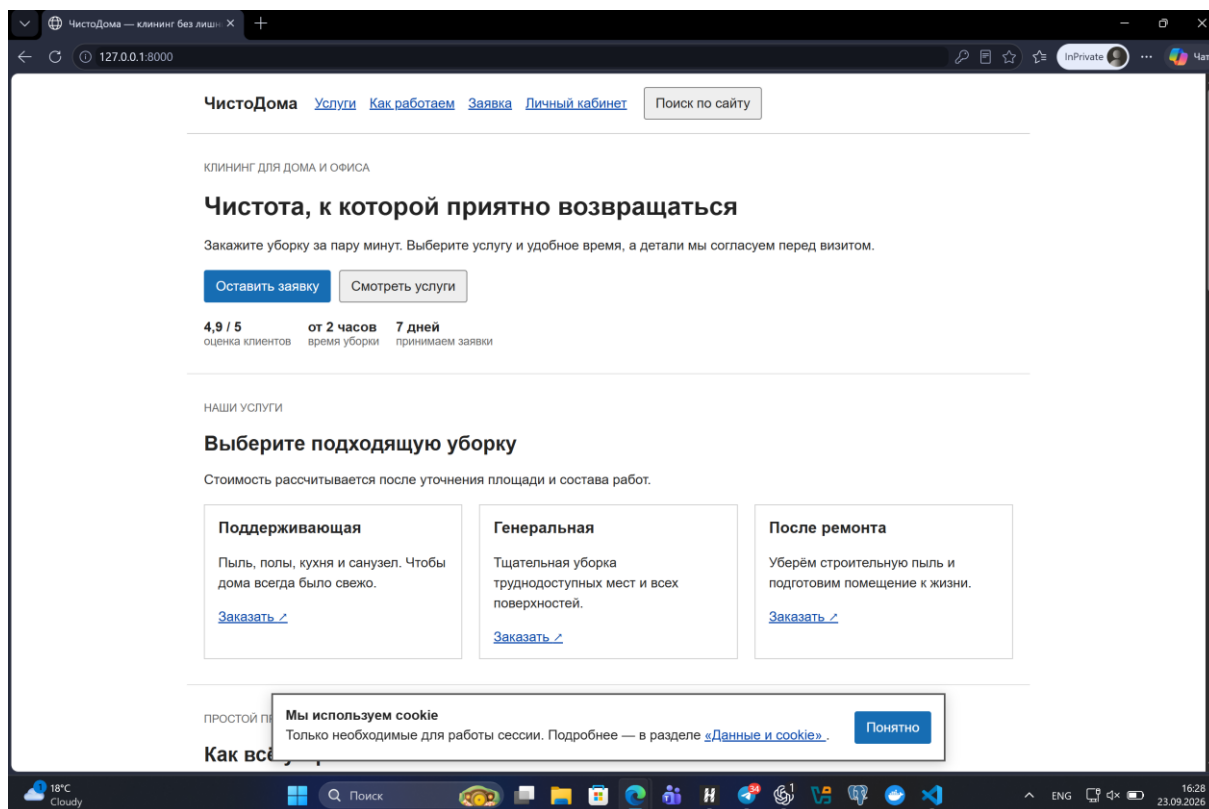


Рисунок 1 — Главная страница и уведомление об использовании cookie

Форма регистрации содержит поля фамилии, имени, отчества, логина, пароля и адреса. Для завершения регистрации пользователь должен установить флажок согласия на обработку персональных данных.

ЛИЧНЫЙ КАБИНЕТ

Все заказы под рукой

Зарегистрируйтесь или войдите, чтобы оформлять заявки и видеть их статус.

Регистрация

Фамилия	Имя
Иванова	Анна
Отчество	
Сергеевна	
Логин	Пароль
анна	Не менее 8 символов
Адрес	
Город, улица, дом	
☐ Согласен(на) на обработку персональных данных. Текст согласия	
Зарегистрироваться	

Рисунок 2 — Форма регистрации пользователя

После входа пользователь может создавать заявки и просматривать их состояние в личном кабинете.

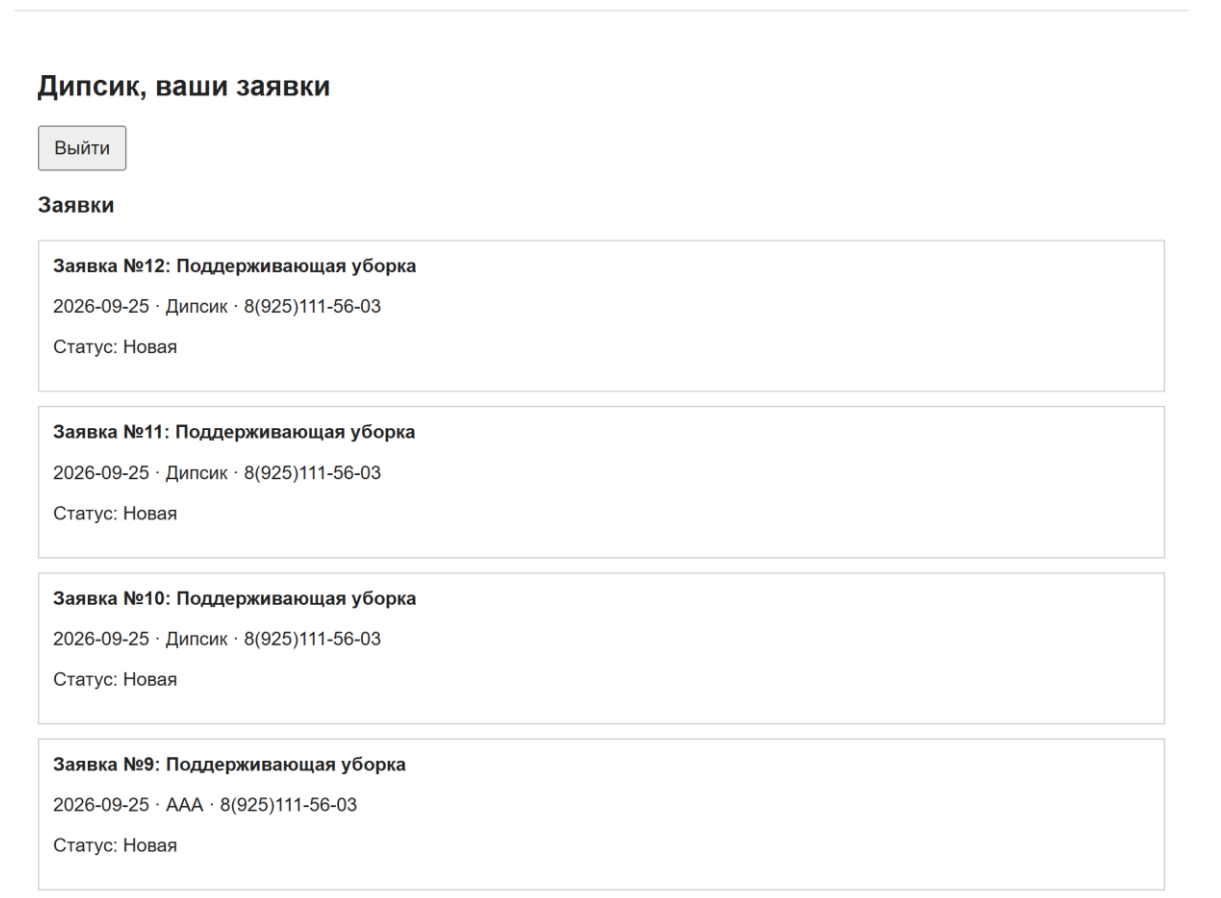


Рисунок 3 — Личный кабинет и список заявок

4 Работа с базой данных PostgreSQL

В PostgreSQL создана база данных cleaning. Таблица users хранит пользователей, sessions — активные сеансы, orders — заявки на уборку. Заявки связаны с пользователями по идентификатору user_id.

Query

```

1 SELECT * FROM public.orders
2 ORDER BY id ASC

```

Data Output

Showing rows: 1 to 11 | Page No: 1 of 1

	id [PK] bigint	user_id bigint	service text	address character varying (100)	visit_date date	phone character varying (16)	status text	created_at timestamp with time zone
1	2	3	Поддерживающая убор...	AAA	2026-09-25	8(999)999-99-99	Новая	2026-09-22 17:09:18.98406
2	3	3	Поддерживающая убор...	AAA	2026-09-25	8(999)999-99-99	Новая	2026-09-22 17:09:25.89453
3	4	3	Поддерживающая убор...	AAA	2026-09-25	8(925)111-56-03	Новая	2026-09-22 17:09:36.09790
4	5	3	Поддерживающая убор...	AAA	2026-09-25	8(925)111-56-03	Новая	2026-09-22 17:09:37.32685
5	6	3	Поддерживающая убор...	AAA	2026-09-25	8(925)111-56-03	Новая	2026-09-22 17:09:37.82968
6	7	3	Поддерживающая убор...	AAA	2026-09-25	8(925)111-56-03	Новая	2026-09-22 17:09:38.49134
7	8	3	Поддерживающая убор...	AAA	2026-09-25	8(925)111-56-03	Новая	2026-09-22 17:09:38.63605
8	9	3	Поддерживающая убор...	AAA	2026-09-25	8(925)111-56-03	Новая	2026-09-22 17:09:38.82608
9	10	3	Поддерживающая убор...	Дипсик	2026-09-25	8(925)111-56-03	Новая	2026-09-22 17:09:46.91607
10	11	3	Поддерживающая убор...	Дипсик	2026-09-25	8(925)111-56-03	Новая	2026-09-22 17:09:47.66084

Total rows: 11 | Query complete 00:00:00.073 | CRLF | Ln 2, Col 17

Рисунок 4 — Записи таблицы orders в pgAdmin 4

5 Заголовки безопасности

Заголовки безопасности формируются сервером в методе `headers_common` и добавляются к каждому HTTP-ответу. Реализованы следующие заголовки:

- `Content-Security-Policy` — разрешает загрузку скриптов, стилей и изображений только из предусмотренных источников, запрещает объекты и встраивание страницы;
- `X-Content-Type-Options: nosniff` — запрещает браузеру подменять заявленный тип содержимого;
- `X-Frame-Options: DENY` — запрещает открывать страницу во фрейме и снижает риск clickjacking;

- Referrer-Policy: strict-origin-when-cross-origin — ограничивает передачу адреса исходной страницы;
- Permissions-Policy — запрещает использование камеры, микрофона и геолокации;
- Cross-Origin-Opener-Policy: same-origin — изолирует страницу от окон других источников;
- Cache-Control: no-store — запрещает сохранять ответы с пользовательскими данными в кеше;
- Strict-Transport-Security — включается в режиме HTTPS и требует использовать защищённое соединение.

```

97 class Handler(BaseHTTPRequestHandler):
98     def headers_common(self):
99         self.send_header("Content-Security-Policy", "default-src 'self'; script-src 'self'; style-s
100         self.send_header("X-Content-Type-Options", "nosniff")
101         self.send_header("X-Frame-Options", "DENY")
102         self.send_header("Referrer-Policy", "strict-origin-when-cross-origin")
103         self.send_header("Permissions-Policy", "camera=(), microphone=(), geolocation=()")
104         self.send_header("Cross-Origin-Opener-Policy", "same-origin")
105         self.send_header("Cache-Control", "no-store")
106         if HTTPS:
107             self.send_header("Strict-Transport-Security", "max-age=31536000; includeSubDomains")
108
109     def respond(self, status, payload, cookie=None):

```

Рисунок 5 — Реализация заголовков безопасности в server.py

В инструментах разработчика выполнена проверка фактических заголовков ответа. Значения совпадают с заданными на сервере.

▼ Response headers	☐ Raw
Cache-Control	no-store
Content-Length	14906
Content-Security-Policy	default-src 'self'; script-src 'self'; style-src 'self'; img-src 'self' data:; object-src 'none'; base-uri 'self'; form-action 'self'; frame-ancestors 'none'
Content-Type	text/html; charset=utf-8
Cross-Origin-Opener-Policy	same-origin
Date	Wed, 23 Sep 2026 13:31:39 GMT
Permissions-Policy	camera=(), microphone=(), geolocation=()
Referrer-Policy	strict-origin-when-cross-origin
Server	BaseHTTP/0.6 Python/3.14.7
X-Content-Type-Options	nosniff
X-Frame-Options	DENY

Рисунок 6 — Заголовки ответа в разделе Network

6 Безопасность cookie

Для авторизации применяется сессионный cookie. В cookie записывается случайный токен, а пароль и персональные данные в него не помещаются. На сервере хранится хеш токена. Cookie создаётся после успешной регистрации или входа.

Для cookie заданы следующие атрибуты:

- HttpOnly — запрещает доступ к cookie из JavaScript;
- SameSite=Lax — ограничивает отправку cookie в межсайтовых запросах;
- Path=/ — задаёт действие cookie для всего сайта;
- Max-Age — ограничивает срок действия сессии;

- Secure — добавляется при работе через HTTPS и запрещает передачу cookie по HTTP;
- префикс __Host- применяется в режиме HTTPS.

```

L41     def cookie_value(self, token, max_age=None):
L42         parts = [f"{COOKIE_NAME}={token}", "Path=/", "HttpOnly", "SameSite=Lax"]
L43         if HTTPS:
L44             parts.append("Secure")
L45         if max_age is not None:
L46             parts.append(f"Max-Age={max_age}")
L47         return "; ".join(parts)
L48
L49     def GET(self):

```

Рисунок 7 — Формирование безопасного cookie в server.py

В локальном режиме сайт работает по HTTP, поэтому Secure не установлен. В инструментах разработчика подтверждены имя session, путь /, HttpOnly и SameSite=Lax.

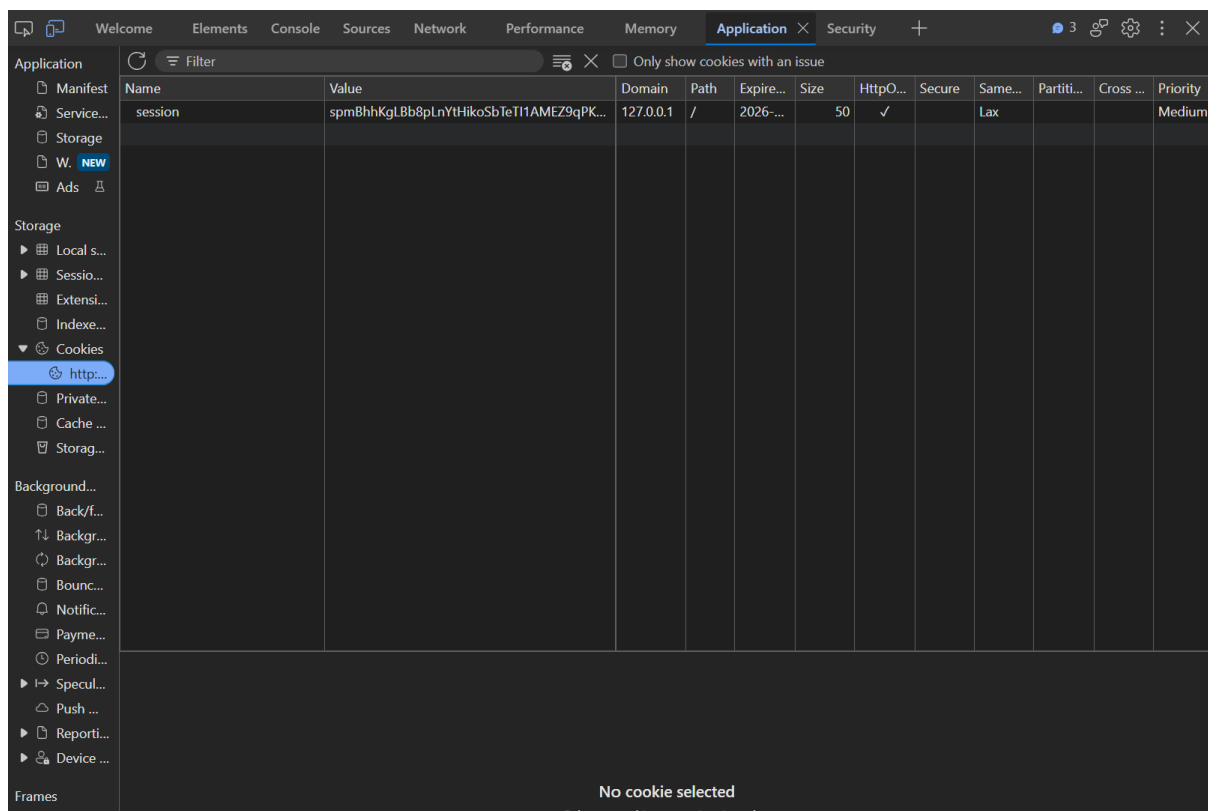


Рисунок 8 — Проверка сессионного cookie в разделе Application

Плашка уведомляет пользователя о применении необходимых cookie. Факт закрытия плашки хранится отдельно в localStorage и не содержит идентификатор сессии.

7 Адаптивность интерфейса

Интерфейс проверен при ширине экрана 393 пикселя. Навигация, кнопки, текст и карточки услуг перестраиваются для просмотра со смартфона.

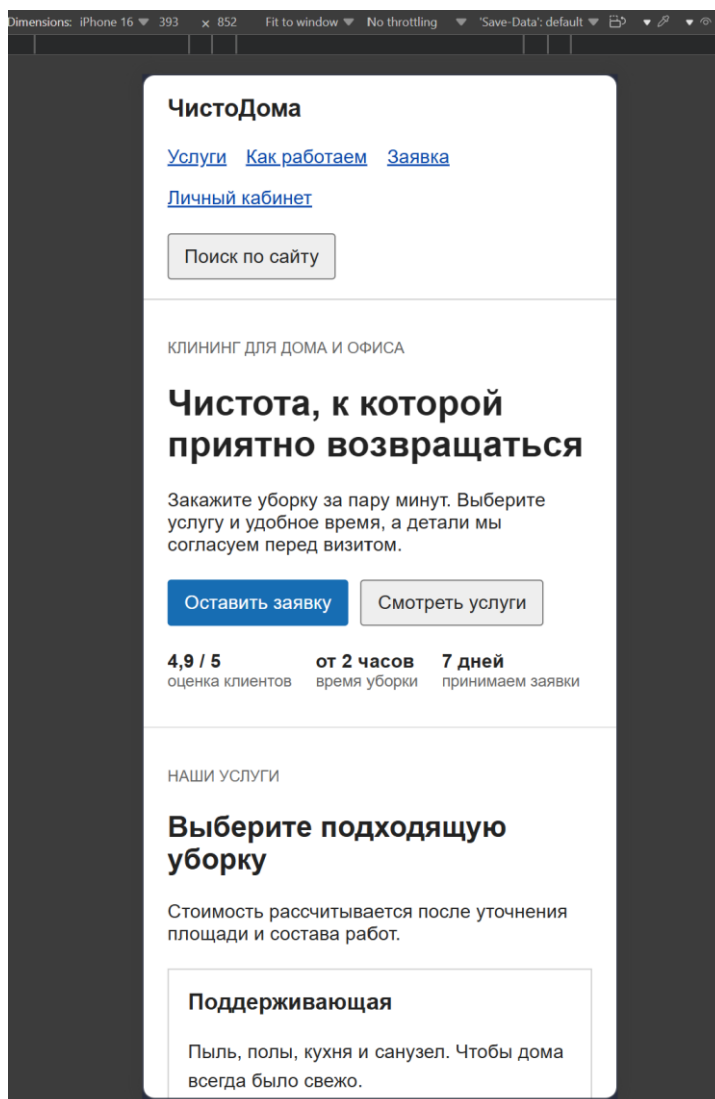


Рисунок 9 — Мобильная версия сайта при ширине 393 пикселя

8 Результат работы

В результате разработан работающий сайт клининга с регистрацией, авторизацией, личным кабинетом, заявками и подключением к PostgreSQL. Сервер отправляет набор защитных HTTP-заголовков. Сессионный cookie имеет HttpOnly, SameSite=Lax, Path и ограниченный срок действия, а при

HTTPS получает Secure и префикс __Host-. Реализация проверена через инструменты разработчика браузера и pgAdmin 4.